KVM-Sentinel-SOC — Comprehensive Executive Breakdown

Hypervisor-Integrated AI Security Operations Center — Source-Grounded Architecture Review

Every claim in this report is backed by an exact file path and line range (`path:line`). Scope is strictly bounded to static codebase inspection; any runtime-only artifact is listed in Section 10.2 («Unverified Areas»).

1. Executive Summary (Non-Technical)

`KVM-Sentinel-SOC` is an end-to-end, three-tier educational security laboratory: a physical `KVM/libvirt` host, an intentionally vulnerable guest virtual machine acting as an `SSH` honeypot (`vm-honeypot`), and a second guest virtual machine (`vm-soc`) running a compact AI-assisted Security Operations Center (`SOC`). When an attacker (either a student on the classroom network or the built-in local attack simulator) brute-forces `SSH` on the honeypot, a `promtail` sidecar container ships authentication logs in real time to `Loki` on the `SOC` guest. A four-stage `Python` agent pipeline (`Parseur` → `Détecteur` → `Analyste` → `Rapporteur`) polls `Loki` every two seconds, detects attack bursts, generates a structured incident report, and dispatches an `HTTP` webhook alert to the host-side `approval_daemon.py`. The approval daemon renders the forensic evidence on the operator's terminal and asks a single interactive confirmation question (`[y/N]`) before executing any containment action. Upon approval, exactly two `virsh` commands are executed: an atomic VM snapshot to preserve forensic state, followed by bringing down the isolated virtual network interface (`NIC`) to quarantine the honeypot. Every operator decision is permanently recorded in an append-only `JSON-lines` audit ledger. The governing design maxim (from `docs/ARCHITECTURE.md:14–15`) is: **AI advises, human decides, hypervisor executes**.

Key architectural strengths:

- **True network isolation**: The honeypot bridge (`virbr1`) disables IP forwarding and `DHCP`, and `vm-honeypot` is provisioned without a default gateway (`host/networks/backend-isolated.xml:6–18`).
- **Forensics before containment**: A point-in-time snapshot is captured with `--atomic` prior to severing the VM's network link (`host/controller/approval_daemon.py:349–355`).
- **Append-only security audit ledger**: Every human decision (`approved` or `dismissed`) is written to a `JSONL` log followed by an explicit `os.fsync` (`host/controller/approval_daemon.py:177–186`).
- **Self-contained incident artifacts**: Both Markdown (`.md`) and structured `JSON` (`.json`) reports are written per incident into the `reports` volume owned by `UID 10002` (`cloud-init-vm2/user-data:78`).
- **Complete operational shell**: A 9-window `tmux` operational dashboard paired with a 13-check health monitor and safe shutdown scripts (`scripts/`).
- **Classroom live-fire mode**: Controlled host `iptables` `DNAT` + `MASQUERADE` rules expose port `2222/TCP` so students on the classroom LAN can attack the isolated honeypot (`host/provisioning/enable-live-fire.sh:130–143`).
- **100% local AI inference**: Contextual analysis runs locally on CPU via `qwen2.5:0.5b` inside `Ollama` on `VM2`, ensuring zero external data exfiltration or cloud telemetry.

2. Architecture Overview

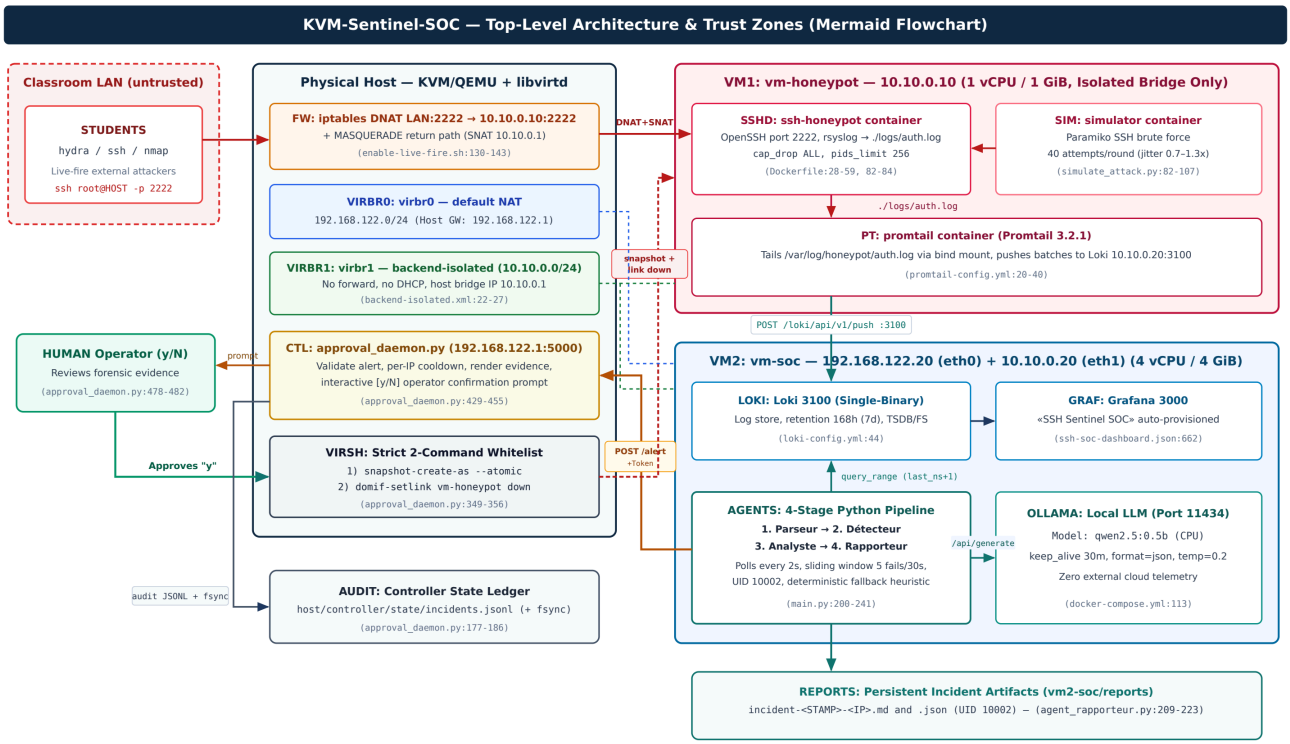
2.1 Component Inventory Table

Component — Source Location	Role, Port & Technology Stack
`ssh-honeypot container` — `vm1-honeypot/docker-compose.yml:27–61` & `ssh-honeypot/Dockerfile:1–98`	Intentionally weakened SSH honeypot on port `2222` writing `auth.log` via `rsyslog`; hardened container boundary (`cap_drop ALL`, `no-new-privileges`, `pids_limit 256`); built on `OpenSSH` + `rsyslog`.
`promtail container` — `vm1-honeypot/docker-compose.yml:94–105` & `vm1-honeypot/promtail/promtail-config.yml:1–40`	Tails `auth.log` and pushes batches to `Loki` at `10.10.0.20:3100`; attaches low-cardinality static labels (`job`, `host`, `source`); runs `Promtail 3.2.1`.
`simulator` — `vm1-honeypot/docker-compose.yml:63–92` & `vm1-honeypot/simulator/simulate_attack.py:1–218`	Real SSH brute-force generator using `paramiko`, gated behind the `manual` Compose profile; runs on `python:3.12-slim` + `paramiko`.
`loki` — `vm2-soc/docker-compose.yml:25–45` & `vm2-soc/loki/loki-config.yml:1–80`	Single-binary log store with 7-day (`168h`) retention and local `tsdb/fs` storage; runs `Loki 3.2.1` on port `3100`.
`grafana` — `vm2-soc/docker-compose.yml:47–78` & `vm2-soc/grafana/provisioning/`	Auto-provisioned «SSH Sentinel SOC» dashboard pinned to datasource UID `loki`; default credentials `admin/sentinel`; runs `Grafana 11.2.2` on port `3000`.
`ollama` & `ollama-init` — `vm2-soc/docker-compose.yml:80–119`	Local CPU inference engine with `keep_alive 30m`; one-shot init container pulls `qwen2.5:0.5b` on first boot; runs `Ollama 0.5.4` on port `11434`.
`agents` — `vm2-soc/agents/main.py:101–241` + 4 agent modules	Four-stage pipeline (`Parseur`, `Détecteur`, `Analyste`, `Rapporteur`) polling every 2 seconds; built with `Python 3.12` + `pydantic 2.9` + `requests`; runs as `UID 10002`.
`approval daemon` — `host/controller/approval_daemon.py:1–652`	Webhook listener bound to `192.168.122.1:5000`; renders forensic evidence and prompts `[y/N]` before executing a 2-command `virsh` whitelist; writes `JSONL` audit log; `Flask 3.0.3` + `Rich`.
`restore-honeypot.sh` — `host/controller/restore-honeypot.sh:1–142`	Reverts `vm-honeypot` to the `clean-baseline` snapshot and brings the isolated virtual `NIC` back online; written in `bash` + `virsh`.

Component — Source Location	Role, Port & Technology Stack
`enable-live-fire.sh` — `host/provisioning/enable-live-fire.sh:1–226`	Installs host DNAT forwarding from port 2222 to `10.10.0.10:2222` with MASQUERADE; uses `iptables` comment tags (`kvm-sentinel-livefire`).
`shutdown-lab.sh` & `cleanup-lab.sh` — `host/provisioning/`	Non-destructive state-preserving lab shutdown versus intentional full lab teardown; written in `bash` + `virsh` + `docker`.
`backend-isolated` (`virbr1`) — `host/networks/backend-isolated.xml:1–27`	Isolated `10.10.0.0/24` bridge with no `<forward>` element and no DHCP; host bridge IP `10.10.0.1`; defined via `libvirt` network XML.
`tmux-dashboard.sh`, `dashboard-status.sh` & `tmux-dashboard-stop.sh` — `scripts/`	Operational cockpit: 9 `tmux` windows, 13 health checks, and recycle-safe process termination via PID+STARTTIME matching; `tmux` + `bash` + `curl`.

2.2 Top-Level Architecture Diagram

The diagram below illustrates the complete system topology and trust boundaries across the untrusted classroom LAN, the physical `KVM/QEMU` host, the isolated honeypot guest (`vm-honeypot`), and the `SOC` analysis guest (`vm-soc`):



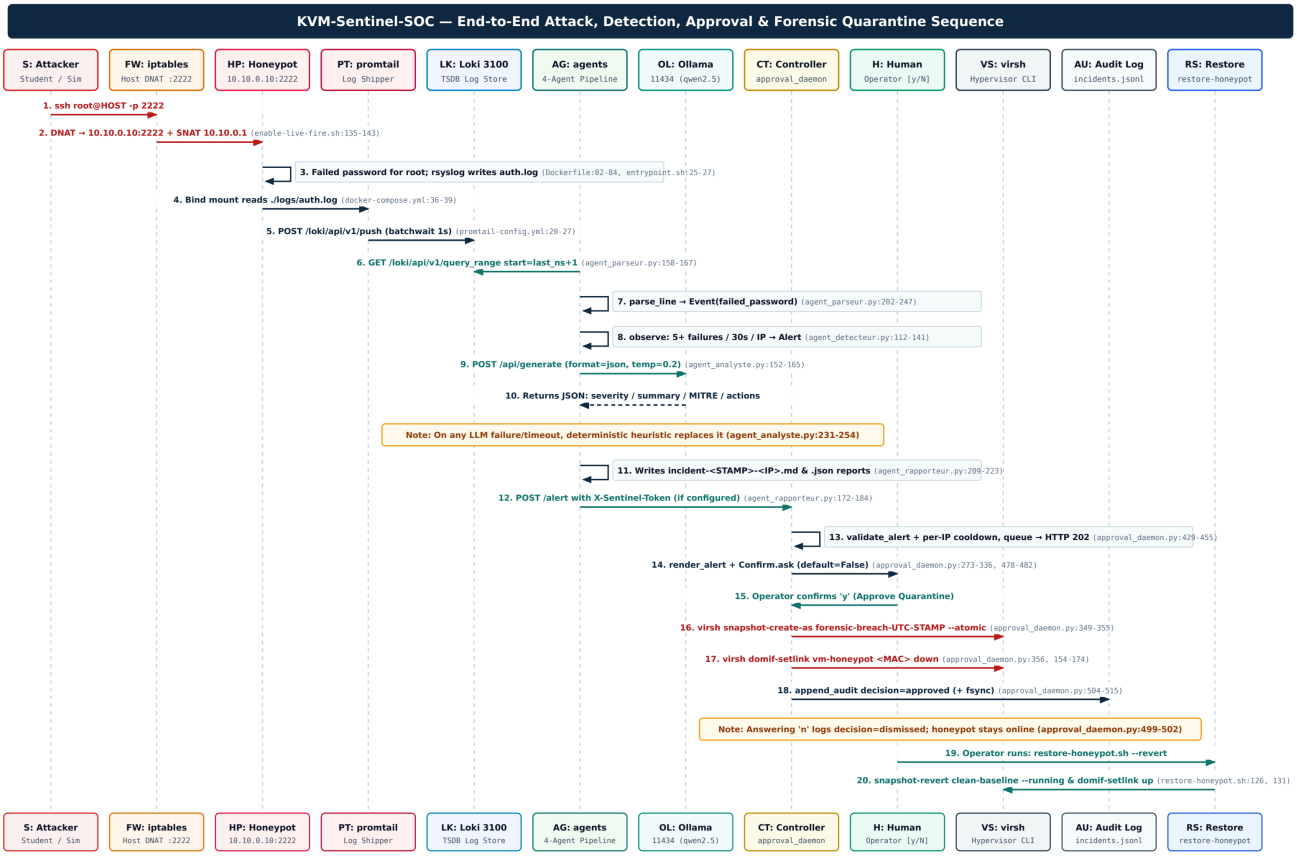
Top-Level Architecture & Trust Zones of `KVM-Sentinel-SOC` (annotated with exact source `path:line` citations).

Network Topology: `virbr0` is `libvirt`'s default `NAT` network on `192.168.122.0/24`, providing `eth0` on `vm-soc` with outbound internet access (`cloud-init-vm2/network-config:11–24`). `virbr1` is defined in

`backend-isolated.xml:22–27` with no `<forward>` element—meaning `libvirt` performs zero routing (`:6–12`, and `CHANGELOG.md:38` documents the removal of `forward mode='none'`, which is invalid in `libvirt 10+`)—and no `DHCP` server (`:13–15`). The bridge address `10.10.0.1` provides a direct return path between the host and both guests (`:16–18, 26`) under the local domain `sentinel.lab` (`:25`). Guest IPs are statically assigned via `cloud-init`: `vm-honeypot eth0` is `10.10.0.10/24` with no gateway and no static routes (`cloud-init-vm1/network-config:9–21`), while `vm-soc eth0` is `192.168.122.20/24` (gateway `192.168.122.1` + external `DNS`) and `eth1` is `10.10.0.20/24` with no gateway (`cloud-init-vm2/network-config:10–33`).

2.3 End-to-End Sequence Diagram

The sequence diagram below traces the complete lifecycle of an incident from the initial `SSH` brute-force attempt through log shipping, parsing, sliding-window detection, `LLM`/heuristic enrichment, operator approval, forensic snapshotting, network quarantine, and baseline restoration:



End-to-End Operational Sequence Diagram from attack initiation to forensic quarantine and restoration.

3. End-to-End Data Flow

3.1 Event Generation: From Attack to `auth.log`

- **Local simulation channel**: The `simulator` container is assigned the `manual` Compose profile (`vm1-honeypot/docker-compose.yml:63–92`) so it never starts automatically during boot; it is invoked explicitly via `docker compose run --rm simulator`, which is the exact command printed in the `shell` window of the `tmux` dashboard.
- **Attack simulator behavior (`simulator/simulate_attack.py`)**: Drives real `SSH` brute-force waves using `paramiko` across 8 usernames and 10 passwords (`:44–58`), injecting the valid `root:toor` credential on

every 17th attempt (:174–177), applying random delay jitter sampled from uniform(0.7, 1.3) between attempts (:192) to mimic human cadence, running 40 attempts per round against the default internal target ssh-honeypot (:115).

- **Classroom live-fire channel**: enable-live-fire.sh installs 4 iptables rules (:136–143) tagged with the comment kvm-sentinel-livefire (:20): DNAT forwards inbound port 2222 on the host interface to 10.10.0.10:2222, paired with MASQUERADE (SNAT 10.10.0.1) on the return path so the gateway-less honeypot can reply to external classroom clients (architectural rationale documented at :10–14), alongside a status subcommand for inspection.
- **Inside the honeypot**: sshd is configured with Port 2222, PermitRootLogin yes, MaxAuthTries 3, and LogLevel VERBOSE (ssh-honeypot/Dockerfile:28–59), a decoy SSH banner (:62–77), and an rsyslog rule routing sshd auth messages to /var/log/honeypot/auth.log (:82–84). entrypoint.sh generates host keys (:16), enforces root:toor (:19), starts rsyslogd (:26), spawns tail -n0 -F on auth.log (:30), and finally executes exec sshd (:33). Compose publishes 2222:2222 (vm1-honeypot/docker-compose.yml:35) under strict container sandboxing (cap_drop ALL, no-new-privileges, pids_limit 256 at :44+).

3.2 From auth.log to Loki

- promtail (vm1-honeypot/docker-compose.yml:94–105) tails auth.log via the shared ./logs bind mount and pushes batches to 10.10.0.20:3100 over vm-soc's isolated eth1 interface (promtail/promtail-config.yml:21), flushing every 1 second (batchwait: 1s) or 1 MiB (:22–23) with exponential backoff from 500ms to 5m across up to 20 retries (:24–27).
- Low-cardinality static labels (job, host, source) are attached (:36–39) for path /var/log/honeypot/auth.log (:40).
- Stream offsets in positions.yaml are stored under /tmp (:17–18)—which is volatile across container restarts; restarting promtail can re-ship historical log lines, leaving deduplication to the downstream agent pipeline (Section 3.4).

3.3 Loki: Passive Log Store

- vm2-soc/loki/loki-config.yml:1–80: Configured in single-binary mode on port 3100 with 168h (7-day) retention, tsdb/fs storage, ingestion limits of 8 MB/s rate and 16 MB burst, auth_enabled: false (acceptable inside the isolated bridge), and ruler enabled with no rule files loaded—making the ruler a dormant component (Section 9).
- Agent runtime environment in vm2-soc/docker-compose.yml:134–150: POLL=2s, LOOKBACK=30s, OLLAMA_TIMEOUT=25s, THRESHOLD=5, WINDOW=30s, COOLDOWN=120s, WEBHOOK=http://192.168.122.1:5000/alert, and SENTINEL_TOKEN left empty by default (:149)—a residual security risk analyzed in Section 6.
- Host routing uses extra_hosts: host-gateway (:156–157) to expose a controlled channel from the agent container to the host webhook listener.

3.4 From Loki to Alert: Parseur and Détecteur

- parseur executes fetch (agent_parseur.py:158–198): queries /loki/api/v1/query_range with start=last_ns+1 and limit=5000, filters out benign lines via NOISE_MARKERS (:70–78), and evaluates ordered regular expressions (:49–66)—matching failed_password first, then invalid_user, then accepted_password—to emit validated Event models (:81–91).

- The high-water mark cursor `last_ns` is persisted atomically via `os.replace` (`:146–155`) only after the entire batch finishes processing in `main.py` (`:231–232`)—leaving a narrow window where a mid-batch crash can re-process or drop an alert (discussed in Section 9).
- **In-memory deduplication**: A bounded `deque` of `20,000` `SHA-1` line digests (`:124`, `:191–194`) suppresses duplicate log lines if `promtail` replays logs after a restart.
- **Sliding-window detection**: `detecteur` maintains a per-source-IP sliding window (`agent_detecteur.py:95–99`), evicting expired timestamps via `_prune` (`:102–110`). Inside `observe` (`:112–141`), successful logins (`accepted_password`) are tracked separately (`:118–120`), while `failed_password` events accumulate in the sliding window (`:122–123`). Reaching 5 failures within 30 seconds triggers an `Alert`, starts a 120-second per-IP cooldown (`:133–135`), and clears the window (`:140`).
- **Severity scoring**: Computed in `_build_alert` (`:151–164`) starting from a base score of `5`, adding `+1` for each threshold doubling (`×2`, `×4`, `×8`), `+1` when targeting accounts in `HIGH_VALUE_USERS` (`:38`), and `+2` when the compromised `root:toor` credential is used.

3.5 From Alert to Incident Report and Webhook Delivery

- `analyste` constructs an `LLM` prompt combining `SYSTEM_PROMPT` (`agent_analyste.py:38–47`) and `OUTPUT_CONTRACT` (`:49–60`), parses JSON tolerantly (`:72–98`), sanitizes strings (`:101–104`), and sends `POST /api/generate` to `Ollama` with `format=json`, `temperature=0.2`, `num_ctx=2048`, and `num_predict=700` (`:160–165`) following an initial model `warm_up` (`:114–128`). Any `LLM` timeout, transport error, or schema failure transparently falls back to a deterministic heuristic (`:231–254`) that assigns `MITRE ATT&CK T1110.001` (Brute Force: Password Guessing) plus `T1078` (Valid Accounts) if `root:toor` succeeded.
- `rapporteur` renders a complete Markdown report (`agent_rapporteur.py:70–133`) using `safe_token` to mask overly long or suspicious strings (`:50–52`), populates `proposed_commands` with the fixed two-command sequence (`:145–151`: `snapshot-create-as forensic-breach-UTC-STAMP` and `domif-setlink ... down`), builds the `UTC`-timestamped `JSON` payload (`:153–163`), and writes both files atomically (`:165–169`). `deliver` retries webhook transmission up to 4 times with exponential backoff (`2^attempt`), skipping retries on `HTTP 4xx` client errors (`:172–206`), and attaches `X-Sentinel-Token` only when configured (`:173–175`).
- `publish` (`:209–238`) always writes the `.md` and `.json` files to `/opt/soc/reports` before attempting network delivery—guaranteeing on-disk forensic persistence even if the host controller is unreachable.

3.6 From Report to Human Decision and Hypervisor Execution

- `host/controller/approval_daemon.py` initializes a `Flask` server (`create_app` at `:388–461`), enforces binding exclusively to the private host bridge IP `192.168.122.1` while rejecting `0.0.0.0` (`:567–579`), caps request payloads at `MAX_CONTENT_LENGTH = 64 KiB` (`:390`), verifies shared tokens in constant time via `hmac.compare_digest` (`:392–396` and `:431–433`), enforces a 120-second per-IP cooldown (`:442–450`), and enqueues valid alerts into a bounded 12-item queue returning `HTTP 202 Accepted` (`:452–455`), served by a background daemon thread (`:607–613`) and interactive main consumer loop (`:629–637`).
- **Input validation (`validate_alert at :213–267`)**: Enforces `REQUIRED_FIELDS` (`:70–80`), validates IP syntax via Python's `ipaddress` module (`:240–244`), pins the target `vm` name to the trusted domain (`:246–247`), clamps `severity` to `[1, 10]` (`:249–254`), and validates `alert_id` against a strict regex (`:263–266`).

- **Evidence rendering (`render_alert` at `:273–336`)**: Synthesizes the two permitted `virsh` commands internally from trusted configuration (`:318–323`), displaying the agent's `proposed_commands` strictly as read-only text without ever executing them (`:332–336`).
- **Operator interaction and quarantine (`perform_quarantine` at `:339–382`)**: Prompts the human operator via `Confirm.ask` with a safe default of `False` (`:478–482`), unless `auto_approve` is explicitly enabled via environment variables (`:472–474`). Upon approval (`y`), it executes `virsh snapshot-create-as ... forensic-breach-UTC-STAMP --atomic` (`:349–355`), resolves the isolated `NIC` MAC address via `domiflist` (`:154–174`), brings the interface down via `virsh domif-setlink ... down` (`:356`), and supports `--dry-run` simulation (`:358–364`). Finally, `process_alert` (`:467–516`) records `approved` or `dismissed` (`:504–515`) via `append_audit` with `os.fsync` (`:177–186`).
- **Honeypot restoration (`host/controller/restore-honeypot.sh`)**: Resolves the virtual NIC MAC address (`:73–87`) and executes `revert` (`:121–141`), running `virsh snapshot-revert ... clean-baseline --running` (`:126`) followed by `virsh domif-setlink ... up` (`:131`).

4. Component Deep-Dive: Provisioning and Architectural Layers

4.1 NixOS Host Layer

- `host/nixos/virtualization.nix` enables `virtualisation.libvirtd` and grants access to authorized operator users (`host/nixos/virtualization.nix:75`), while `flake.nix` unifies `docker` and `libvirtd` dependencies reproducibly.

4.2 Automated Lab Provisioning (`deploy-lab.sh`)

- **Preflight verification (`host/provisioning/deploy-lab.sh:169–208`)**: Fails fast if required binaries, `virsh` connectivity, virtual networks, or minimum free host RAM (`~5500 MiB` at `:196`) are missing.
- **Pinned cloud image**: Downloads the official `Ubuntu 24.04 (Noble)` cloud image and verifies its `SHA256` checksum (`:245–267`).
- **Copy-on-write overlays**: Creates lightweight `qcow2` overlay disks backed by the base cloud image via `qemu-img` (`:269–281`).
- **Cloud-init rendering (`render_user_data` at `:304–390`)**: Generates `user-data`, `meta-data`, and `network-config` for each VM. In `cloud-init-vm1/user-data`, credentials `soc:sentinel` are set at line `34`, a TCP readiness `beacon` script is installed into `/usr/local/bin` listening on `10.10.0.10:9999` (`cloud-init-vm1/user-data:75–96`), and `runcmd` (`:98–120`) verifies that the `ssh-honeypot` container is running before writing the ready marker and starting the `kvm-sentinel-ready` `systemd` unit.
- **Seed ISO generation**: Packages `NoCloud` configuration into a `-volid cidata` ISO image via `genisoimage` (`:392–417`).
- **VM1 installation (`virt-install` at `:429–446`)**: Provisions `1 vCPU / 1024 MiB RAM`, attaches the overlay disk and both `default` (bootstrap NAT) and `backend-isolated` networks with `--noautoconsole`.
- **VM2 installation (`virt-install` at `:455–473`)**: Provisions `4 vCPU / 4096 MiB RAM` (note: the printed summary banner at the end of `deploy-lab.sh` erroneously prints `5120 MiB` for `VM2`—see Section 9).

4.3 Post-Boot Finalization and Baseline Snapshot

- `wait_for_cloud_init` (`:513–533`) polls the TCP `9999` readiness beacon—which only responds once `ssh-honeypot` is verified active (`runcmd:98–120`).

- `detach_bootstrap_nic` (:535–552): Hot-detaches the temporary `NAT` bootstrap interface from `VM1` immediately after provisioning, leaving `vm-honeypot` exclusively on the air-gapped `backend-isolated` bridge.
- `clean-baseline` snapshot (:554–565): Captures the pristine post-provisioning state of `VM1` for subsequent incident recovery.
- Final summary banner (:566–586): Prints operational endpoints (containing the `5120 MiB` label discrepancy documented in Section 9).

4.4 Honeypot Tier (`vm-honeypot`) in Detail

- `vm1-honeypot/docker-compose.yml`: Runs `ssh-honeypot` (:27–61) exposing `2222:2222` (:35) and mounting `./logs` (:36–39); applies `cap_drop ALL`, `no-new-privileges`, and `pids_limit 256` (:44+); defines internal bridge `honeypot-net` on `172.31.240.0/24` (:116); gates `simulator` behind `profiles: ["manual"]` (:68–69); runs `promtail` (:94–105).
- `ssh-honeypot/Dockerfile`: Configures intentionally weak `sshd` parameters (:28–59: `Port 2222`, `PermitRootLogin yes`, `MaxAuthTries 3`, `LogLevel VERBOSE`), installs a realistic decoy banner (:62–77), and configures `rsyslog` to write `/var/log/honeypot/auth.log` (:82–84).
- `ssh-honeypot/entrypoint.sh`: Generates host keys via `ssh-keygen -A` (:16), sets `root:toor` (:19), launches `rsyslogd` (:26), tails `auth.log` (:30), and runs `exec sshd` (:33).
- `simulator/simulate_attack.py`: Iterates across 8 usernames and 10 passwords (:44–58), injects `root:toor` every 17th attempt (:174–177), applies `uniform(0.7, 1.3)` timing jitter (:192), and targets `ssh-honeypot` by default (:115).

4.5 SOC Brain Tier (`vm-soc`) in Detail

- `vm2-soc/docker-compose.yml`: Runs `loki:3.2.1` on port `3100` with `/ready` healthcheck (:25–45, healthcheck :38–44); `grafana:11.2.2` with `admin/sentinel` login (:47–78); `ollama:0.5.4` with `KEEP_ALIVE=30m` and `NUM_PARALLEL=1` (:89–92); one-shot `ollama-init` pulling `qwen2.5:0.5b` (:113); and `agents` with detection environment variables (:134–150) and `extra_hosts` mapping (:156–157).
- `vm2-soc/loki/loki-config.yml:1–80`: Single-binary mode on `3100`, `168h` retention, `tsdb/fs` storage, `8 MB/s` ingestion rate (`16 MB` burst), `structured_metadata: true`, and an unpopulated `ruler` block (Section 9).
- Grafana provisioning in `vm2-soc/grafana/provisioning/`: Pins datasource `uid: loki` and loads `ssh-soc-dashboard.json` (10 panels, 10s auto-refresh) using `count_over_time` queries on `Failed password` and regex extraction for `src_ip`.

4.6 Agent Runtime Loop (`vm2-soc/agents/main.py`)

- `Config` initialization (:101–117): Parses environment variables via typed helpers (:48–61), converts timestamps via `iso_to_ns` (:64–69), updates a file-based `heartbeat` gauge (:72–79), maintains a 50-sample latency `deque` (:141), and sets a code default of `ollama_timeout = 180s` (:109) overridden to `25s` by Compose (Section 9).
- Main polling loop (:197–239): Runs `warm_up` on startup (:191–196), applies exponential backoff starting at `1s` (×2 up to `30s`) on errors (:197–215), and dispatches alerts through `handle_alert` (:166–188).
- `handle_alert` invokes `analyste` enrichment followed by `rapporteur` report generation and webhook delivery, logs a preflight warning when `SENTINEL_TOKEN` is unset (:162–163), updates the heartbeat file

after each batch (`:233`), and sleeps for the poll interval (`:238`).

- Batch cursor semantics: `last_ns` is committed to disk only after all events in the fetched batch have been processed (`:231–232`).

4.7 Host Controller and Operational Utilities

- `host/controller/approval_daemon.py`: Defines `Config` (`:105–124`) with 120s cooldown and `state/incidents.jsonl`; executes `virsh` via shell-free `argv` arrays (`run_virsh` at `:137–151`); resolves NIC MACs via `resolve_nic_mac` (`:154–174`); persists audit records with `os.fsync` (`append_audit` at `:177–186`); refuses binding to `0.0.0.0` (`:567–579`); and runs `Flask` in a background daemon thread (`:607–613`) feeding an interactive prompt loop (`:629–637`).
- `restore-honeypot.sh`: Resolves NIC MAC (`:73–87`) and reverts to `clean-baseline` via `snapshot-revert --running` (`:126`) and `domif-setlink up` (`:131`).
- `host/provisioning/enable-live-fire.sh`: Manages comment-tagged `iptables DNAT/MASQUERADE` rules (`:20`, `:136–143`) and `status` reporting.
- Shutdown vs. teardown: `shutdown-lab.sh` gracefully stops Compose stacks and VMs while preserving state, whereas `cleanup-lab.sh` performs an intentional full teardown.
- `scripts/tmux-dashboard.sh`: Registers components (`:223–260`), builds 9 `tmux` windows (`:449–537`), and records `PID+STARTTIME` pidfiles (`:572–592`); `dashboard-status.sh` runs 13 health checks (`:180–454`); `tmux-dashboard-stop.sh` prevents PID-recycle collateral damage by verifying `PID+STARTTIME` before sending `SIGTERM`/`SIGKILL` (`:129–133`) and supports `--stop-stacks` and `--stop-vms`.

5. Detection Logic and AI Enrichment Pipeline

5.1 Parsing Layer (`Parseur`)

- **Specificity-ordered regex evaluation (`agent_parseur.py:49–66`)**: Evaluates `failed_password` first, followed by `invalid_user`, and then `accepted_password`—ensuring specific failure patterns are matched before broader fallback patterns.
- **Noise suppression (`NOISE_MARKERS` at `:70–78`)**: Drops benign `sshd` disconnect messages, banner exchanges, `systemd` chatter, and local health probes prior to regex matching.
- **Structured `Event` model (`:81–91`)**: Normalizes parsed lines into typed events (`:40–46`: `failed_password`, `invalid_user`, `accepted_password`, etc.).
- **Deduplication and cursor persistence**: Combines a `20,000`-entry `SHA-1` digest `deque` (`:124`, `:191–194`) with `query_range` pagination starting at `last_ns+1` (`limit=5000` at `:158–198`) and atomic `os.replace` cursor commits (`:146–155`).

5.2 Detection Layer (`Détecteur`)

- **Per-IP sliding window**: Maintains a 30-second sliding window per source IP (`agent_detecteur.py:95–99`), pruning stale timestamps on each observation via `_prune` (`:102–110`).
- **Observation logic (`observe` at `:112–141`)**: Tracks `accepted_password` events separately for breach correlation (`:118–120`), while accumulating `failed_password` events toward the threshold (`:122–123`). Reaching 5 failures within 30 seconds emits an `Alert`, activates a 120-second per-IP cooldown (`:133–135`), and flushes the window (`:140`).

- **High-value target & credential tracking**: Attempts against accounts listed in `HIGH_VALUE_USERS` (`:38`) elevate severity, and successful authentication with `root:toor` is flagged as a confirmed honeypot compromise.
- **Explainable severity formula (`_build_alert` at `:151–164`)**: Starts at base `5`, adds `+1` per threshold doubling (×2/×4/×8), `+1` for high-value accounts, and `+2` for compromised `root:toor` credentials—clamping the final score to `[1, 10]` with human-readable evidence strings.

5.3 AI Analysis Layer (`Analyste`)

- **Prompt engineering and output contract**: Combines `SYSTEM_PROMPT` (`agent_analyste.py:38–47`) with `OUTPUT_CONTRACT` (`:49–60`), requiring an integer `severity` in `1–10`, a concise `summary`, a `mitre_attack` technique list, and recommended `actions` restricted to `ALLOWED_ACTIONS` (`:35`).
- **Tolerant JSON extraction and sanitization**: Extracts JSON payloads resiliently (`:72–98`) and strips unsafe control characters (`:101–104`), while `build_prompt` (`:131–149`) embeds the observation window and log evidence.
- **Local LLM invocation (`:152–195`)**: Sends `POST /api/generate` with `format=json`, `temperature=0.2`, `num_ctx=2048`, and `num_predict=700` (`:160–165`), bounded by the configured timeout (`25s` in Compose, `180s` default in `main.py:109`), after pre-warming the model via `warm_up` (`agent_analyste.py:114–128`).
- **Deterministic heuristic fallback (`:231–254`)**: Guarantees 100% pipeline continuity if `Ollama` times out or returns malformed output—assigning `MITRE ATT&CK T1110.001` by default, adding `T1078` when `root:toor` is observed, and clamping scores in `_normalize` (`:202–203`).
- **Why this matters**: Because CPU inference on a small model can experience latency spikes, decoupling detection from `LLM` availability ensures every attack still produces a valid, actionable incident report.

5.4 Reporting and Delivery Layer (`Rapporteur`)

- **Structured Markdown generation (`agent_rapporteur.py:70–133`)**: Renders standardized report sections covering executive summary, forensic evidence, timeline, `MITRE ATT&CK` mapping, and proposed containment commands.
- **Token sanitization (`safe_token` at `:50–52`)**: Truncates and masks overly long or untrusted inline strings from log payloads so attacker-controlled usernames cannot corrupt report formatting.
- **Hardcoded `proposed_commands` (`:145–151`)**: Always emits the exact two-command pair (`virsh snapshot-create-as ... forensic-breach-UTC-STAMP` and `virsh domif-setlink ... down`).
- **Atomic disk persistence and retry delivery**: Builds the `JSON` payload (`:153–163`), writes files atomically (`:165–169`), and transmits alerts via `deliver` using 4 attempts with `2^attempt` backoff (skipping retries on `4xx` responses at `:172–206`), attaching `X-Sentinel-Token` when present (`:173–175`). `publish` (`:209–238`) writes `.md` and `.json` artifacts to disk before webhook transmission.

6. Security Model and Trust Boundaries

6.1 Five Trust Zones

- **Zone 1 — Classroom LAN (Untrusted)**: External network; only port `2222/TCP` is exposed (and only when `live-fire` mode is explicitly enabled via `enable-live-fire.sh:136–143`).

- **Zone 2 — Physical Host**: Highest trust boundary; `approval_daemon.py` binds exclusively to `192.168.122.1` and refuses `0.0.0.0` (`approval_daemon.py:567–579`).
- **Zone 3 — Isolated Bridge `virbr1` (`10.10.0.0/24`)**: Air-gapped internal network with no IP forwarding and no DHCP (`backend-isolated.xml:6–18`); `vm-honeypot` (`10.10.0.10`) has no default gateway (`cloud-init-vm1/network-config:9–21`).
- **Zone 4 — Default NAT Bridge `virbr0` (`192.168.122.0/24`)**: `vm-soc` connects `eth0` here (for container image pulls and host webhook delivery) while bridging `eth1` onto `virbr1` (`cloud-init-vm2/network-config:10–33`).
- **Zone 5 — Container Sandboxing**: Honeypot container enforces `cap_drop ALL`, `no-new-privileges`, and `pids_limit 256` (`vm1-honeypot/docker-compose.yml:44+`).

6.2 Deliberate Execution Hardening

- **Shell-free `virsh` execution**: Commands are invoked via `argv` lists without a shell (`approval_daemon.py:137–151`), locked to a strict two-command whitelist (`snapshot-create-as` and `domif-setlink down` at `:349–356`). Agent-supplied `proposed_commands` are displayed for operator review only and are never executed (`:332–336`).
- **Multi-layer `/alert` validation**: Validates IP addresses via `ipaddress` (`:240–244`), pins `vm` to the configured domain (`:246–247`), clamps `severity` (`:249–254`), checks `alert_id` against a strict regex (`:263–266`), limits request body size to `64 KiB` (`:390`), and queues up to 12 alerts with `HTTP 202` (`:452–455`).
- **Human-in-the-loop gate**: `Confirm.ask` defaults to `False` (`:478–482`); `auto_approve` requires explicit environment opt-in (`:472–474`), and `--dry-run` is supported (`:358–364`).
- **Mandatory forensic audit**: Every decision is appended to `state/incidents.jsonl` followed by `os.fsync` (`:177–186`).

6.3 Residual Risks and Security Recommendations

> ⚠ **Operational Security Warning**: Before enabling classroom `Live-Fire` mode on a shared network, operators must configure a strong `SENTINEL_TOKEN` secret and rotate the default `Grafana` credentials (`admin/sentinel`).

- **`SENTINEL_TOKEN` is empty by default** (`vm2-soc/docker-compose.yml:149`): Without a token configured, `/alert` relies on network reachability, schema validation, and the interactive human prompt rather than cryptographic authentication.
- **Default `Grafana` credentials (`admin/sentinel`)** (`vm2-soc/docker-compose.yml:56–58`): Should be rotated before classroom exposure.
- **Unauthenticated `Loki` endpoint** (`auth_enabled: false` in `loki/loki-config.yml:1–80`): Acceptable only because port `3100` is bound within the isolated network.
- **Per-IP detection window and 120s cooldown**: Distributed low-and-slow brute-force attacks spread across many source IPs (<5 attempts per IP per 30s) will stay below the per-IP threshold (`agent_detecteur.py:95–123`).
- **Log-borne prompt injection via crafted SSH usernames**: Impact is structurally contained because `analyste` restricts actions to `ALLOWED_ACTIONS` (`:35`) and `approval_daemon.py` constructs `virsh`

commands internally rather than executing LLM text (:318–336).

7. Failure Modes and Resilience Analysis

7.1 Retry and Backoff Policies

- **Agent polling loop**: Exponential backoff starting at 1s and doubling on each consecutive error up to 30s (main.py:197–215).
- **promtail log shipping**: Exponential backoff from 500ms to 5m across up to 20 attempts (promtail/promtail-config.yml:24–27).
- **rapporteur webhook delivery**: deliver performs 4 attempts with 2^attempt backoff and does not retry HTTP 4xx errors (agent_rapporteur.py:172–206).
- **Host controller queue**: Bounded 12-item queue absorbs bursts with immediate HTTP 202 responses (approval_daemon.py:452–455), while the 120s per-IP cooldown (:442–450) suppresses alert storms.

7.2 Restart Semantics and State Persistence

- **promtail positions in /tmp** (promtail/promtail-config.yml:17–18): Container restarts may replay old log lines; the 20,000-item SHA-1 deque in agent_parseur.py:124, 191–194 prevents duplicate event emission.
- **last_ns cursor persistence**: Atomically updated via os.replace (:146–155) and reloaded on startup (:128–144), whereas in-memory structures (dedup deque, sliding windows, cooldown maps) reset when the agents container restarts.
- **Post-batch cursor commit**: last_ns is committed after the full batch completes (main.py:231–232)—see Section 9.

7.3 Graceful Degradation Modes

- **Ollama down or slow**: analyste times out and switches to the deterministic heuristic (agent_analyste.py:231–254); the repository README documents a full end-to-end verification on 2026-11-03 exercising this exact fallback path.
- **Loki unavailable**: promtail buffers and retries up to 20 times (promtail/promtail-config.yml:24–27), while parseur fetch failures trigger the main loop's exponential backoff (main.py:197–215).
- **Host controller unreachable**: deliver exhausts its 4 retries without blocking the detection loop, while .md and .json incident reports remain safely written on disk (agent_rapporteur.py:209–238). No autonomous quarantine occurs—failing safe by keeping the honeypot online until human review.
- **Grafana unavailable**: Zero impact on detection, reporting, or containment; Grafana is strictly observational.

7.4 Source-Documented Failure Semantics

- The module docstring in main.py:11–18 explicitly documents the runtime guarantees for heartbeat updates, polling intervals, exponential backoff, and model warm-up.

7.5 Post-Quarantine Recovery

- To restore the honeypot after containment: run ./host/controller/restore-honeypot.sh --revert, which executes snapshot-revert --running (:126) to clean-baseline and brings the isolated NIC

back up via `domif-setlink up` (`:131`).

- Verification: check `virsh snapshot-list vm-honeypot` and inspect the tail of `host/controller/state/incidents.jsonl`.

8. Operational Runbook

8.1 Bringing Up the Lab from Scratch

```
sudo nixos-rebuild switch --flake ./host/nixos#default
./host/provisioning/deploy-lab.sh
python3 host/controller/approval_daemon.py
ssh soc@192.168.122.20 'sudo docker compose -f /opt/soc/docker-compose.yml up -d'
cp .env.example .env   # One-time setup: configure DASH_VM*_PASSWORD or SSH key
./scripts/tmux-dashboard.sh
```

8.2 Day-to-Day Operations

- **Trigger a manual simulated attack**: Run `ssh soc@10.10.0.10 'sudo docker compose -f /opt/honeypot/docker-compose.yml run --rm simulator'` using credentials `soc:sentinel` (`cloud-init-vm1/user-data:34`); `/opt/honeypot` is populated during `runcmd` (`:120`).
- **Enable classroom live-fire mode**: Run `sudo ./host/provisioning/enable-live-fire.sh` followed by `status`; students can then attack port `2222` on the host's LAN IP (`:136–143`).
- **Respond to an incident alert**: The `controller` window renders the alert evidence and prompts `[y/N]`. Pressing `y` takes an atomic forensic snapshot, brings down the honeypot NIC, and flushes the audit record via `append_audit` + `fsync`. Verify forensic artifacts via `virsh snapshot-list vm-honeypot` and `tail host/controller/state/incidents.jsonl`.
- **Restore the honeypot**: Run `./host/controller/restore-honeypot.sh --revert`.
- **Stop or tear down the lab**: Run `./host/provisioning/shutdown-lab.sh --dry-run` (then without `--dry-run`) to stop stacks and guests non-destructively; use `./host/provisioning/cleanup-lab.sh` only for intentional full destruction.
- **Health monitoring and cockpit shutdown**: Run `./scripts/dashboard-status.sh --watch 5` for continuous monitoring, and `./scripts/tmux-dashboard-stop.sh` (with optional `--stop-stacks` and `--stop-vms`) for clean teardown.

8.3 Network Port Matrix

Port	Service & Network Scope	Source Reference
`2222/TCP`	Host `DNAT` forwarding to `10.10.0.10:2222` (active in `live-fire` mode only)	`enable-live-fire.sh:136–143`
`3100/TCP`	`Loki` ingestion/query API on `vm-soc` `eth1` (`10.10.0.20`) inside isolated bridge	`loki/loki-config.yml:1–80`
`3000/TCP`	`Grafana` web UI on `192.168.122.20` (reachable from host over `virbr0`)	`vm2-soc/docker-compose.yml:47–78`

Port	Service & Network Scope	Source Reference
11434/TCP	Ollama local inference API internal to vm-soc	vm2-soc/docker-compose.yml:89–92
5000/TCP	Host approval_daemon.py webhook listener on 192.168.122.1	approval_daemon.py:388–461
9999/TCP	One-time provisioning readiness beacon on VM1 (10.10.0.10)	cloud-init-vm1/user-data:75–96

8.4 Forensic & Operational Artifact Paths

- **Incident reports**: Per-incident incident-<STAMP>-<IP>.md and .json files in the reports directory on vm2-soc, owned by UID 10002 (cloud-init-vm2/user-data:78).
- **Controller audit ledger**: host/controller/state/incidents.jsonl flushed with os.fsync (approval_daemon.py:105–186).
- **Dashboard logs and pidfiles**: logs/tmux-dashboard/ and run/<session>/ (scripts/tmux-dashboard.sh:572–592).
- **Hypervisor snapshots**: clean-baseline (deploy-lab.sh:554–565) and forensic-breach-UTC-STAMP (approval_daemon.py:349–355).

8.5 Critical Environment Variables

- SENTINEL_TOKEN: Empty by default in vm2-soc/docker-compose.yml:149—must be set on both agent and controller before classroom deployment (Section 6.3).
- DASH_VM*_PASSWORD & DASH_SSH_KEY: Authentication parameters for the tmux operational dashboard.
- Detection & LLM tuning parameters: POLL, LOOKBACK, THRESHOLD, WINDOW, COOLDOWN, OLLAMA_TIMEOUT, and WEBHOOK in vm2-soc/docker-compose.yml:134–150.

9. Documented Discrepancies, Dormant Code & Improvement Roadmap

9.1 Verified Code-vs-Documentation Discrepancies

- **vm-soc RAM label in deploy-lab.sh summary**: The summary banner at deploy-lab.sh:575 prints 5120 MiB for vm-soc, whereas virt-install actually allocates 4096 MiB (:459)—5120 MiB is the combined RAM of both VMs (1024 + 4096).
- **Grafana panel threshold wording**: Dashboard descriptions state «more than 5 failed logins» (ssh-soc-dashboard.json:26, 313), whereas the detector code triggers at >= 5 (agent_detecteur.py:130).
- **Stale references in TROUBLESHOOTING.md**: Retains legacy promtail configuration lines and a hardcoded IP 172.31.240.66, whereas vm1 defines subnet 172.31.240.0/24 without static container IPs (vm1-honeypot/docker-compose.yml:116).
- **OLLAMA_TIMEOUT default in code vs. changelog**: CHANGELOG.md:43 states OLLAMA_TIMEOUT was lowered from 180 to 25 seconds, but the Python default in main.py:109 remains 180 and is only overridden to 25 via vm2-soc/docker-compose.yml:134–150.
- **Dormant Loki ruler block**: ruler is enabled in vm2-soc/loki/loki-config.yml:1–80 with zero rule files configured.

- **Internet access statement in `ARCHITECTURE.md`**: Claims «Internet access for both VMs», which is true for `VM1` only during the brief initial `cloud-init` bootstrap before `detach_bootstrap_nic` removes its NAT interface (`deploy-lab.sh:535–552`).

9.2 Engineering Fragilities

- **Volatile `promtail` positions in `/tmp`** (`promtail/promtail-config.yml:17–18`): Container restarts re-read `auth.log` from the beginning; the `20,000`-line `SHA-1` deque in `parseur` mitigates this but is bounded in size.
- **Unbounded cooldown map in `approval_daemon.py`** (`:442–450`): Per-IP cooldown entries are never evicted, causing minor memory growth over long-running sessions.
- **Batch cursor commit window** (`main.py:231–232`): Committing `last_ns` after full batch completion means an unhandled exception mid-batch could re-process earlier alerts in that batch.
- **Liveness vs. freshness in dashboard health checks** (`scripts/dashboard-status.sh:180–454`): Checks verify process presence and HTTP port responsiveness rather than `heartbeat` timestamp freshness.
- **`Promtail` maintenance status**: Noted in `README` Known Issues, with a planned migration path to `Grafana Alloy` once memory overhead permits.

9.3 Prioritized Improvement Checklist

- Require a non-empty, high-entropy `SENTINEL_TOKEN` before starting in `live-fire` mode (Section 6.3).
- Upgrade the `/alert` webhook transport from plain `HTTP` to `HTTPS/mTLS` across `virbr0`.
- Add a global target-wide sliding window alongside the per-IP window to detect distributed multi-source brute-force attacks (Section 6.3).
- Add unit tests covering the `_build_alert` severity scoring formula and `agent_analyste.py` JSON output contract normalization.
- Periodically prune expired entries from the controller's `cooldown` dictionary and validate `heartbeat` age in `dashboard-status.sh`.

10. Glossary and Unverified Areas

10.1 Technical Glossary

- **`Parseur`**: Stage 1 log parser—queries `Loki`, filters noise, and emits structured `Event` objects (`agent_parseur.py:40–46`).
- **`Détecteur`**: Stage 2 detector—maintains per-IP sliding windows and emits `Alert` objects upon threshold breach (`agent_detecteur.py:112–141`).
- **`Analyste`**: Stage 3 AI analyst—enriches alerts via `Ollama` with a deterministic heuristic fallback (`agent_analyste.py:152–195`, `:231–254`).
- **`Rapporteur`**: Stage 4 reporter—writes `.md` and `.json` incident reports and delivers webhook alerts to the host controller (`agent_rapporteur.py:70–238`).
- **`live-fire`**: Classroom exercise mode forwarding external traffic on host port `2222` to the honeypot via `DNAT` (`enable-live-fire.sh:130–143`).

- **`backend-isolated (virbr1)`**: Air-gapped `10.10.0.0/24` virtual bridge without routing or `DHCP` (`backend-isolated.xml:22–27`).
- **`forensic-breach-UTC-STAMP`**: Point-in-time VM snapshot created atomically upon operator approval prior to network isolation (`approval_daemon.py:349–355`).
- **`clean-baseline`**: Pristine post-provisioning VM snapshot used by `restore-honeypot.sh` (`deploy-lab.sh:554–565`).
- **`beacon`**: One-shot TCP service on port `9999` signaling `VM1` `cloud-init` completion during provisioning (`cloud-init-vm1/user-data:75–96`).
- **`cidata`**: Volume ID of the `NoCloud` seed ISO attached to each VM during provisioning (`deploy-lab.sh:392–417`).
- **`domif-setlink`**: `virsh` command used to administratively sever (`down`) or restore (`up`) the honeypot's virtual NIC (`approval_daemon.py:356`).

10.2 Unverified Areas

- Binary disk/image artifacts (`*.qcow2`, seed ISO images, `*.pyc`) were not inspected; their runtime state is verified only during live execution.
- The lab was not booted live during this static review session; the `2026-11-03` end-to-end verification note in `README` serves as corroborating documentation rather than independent live testing.
- The containerized controller deployment path referenced in `§8.1` of `docs/01-INSTALL-NIXOS.md` was not audited line-by-line.
- Internal library versions and runtime weights inside the upstream `ollama` container image lie outside the repository source tree.
- Both `Mermaid` specifications in Sections `2.2` and `2.3` have been rendered into high-resolution vector/PNG diagrams (`architecture-diagram.svg` and `sequence-diagram.svg`) and embedded directly into this compiled report.

ℹ **Independent Verification Methodology**: Every `path:line` citation in this report can be verified directly against the source repository using standard CLI queries such as `grep -n "snapshot-create-as" host/controller/approval_daemon.py` or `grep -n "forensic-breach" host/controller/approval_daemon.py`. Any discrepancy between a citation here and the repository source should be treated as an error in this report rather than in the system.
